

LEARNSPHERE EDTECH

NIST CYBERSECURITY FRAMEWORK (CSF) 2.0

STEP 4 — TARGET MATURITY ASSESSMENT

Detailed Current-to-Target Profile and Management Rationale

DOCUMENT ID	LS-NIST-001
PROJECT	Project 2 – NIST CSF 2.0 Gap Assessment
VERSION	1.0
ASSESSMENT DATE	04-Sep-2026
ORGANIZATION	LearnSphere EdTech
SCOPE FOCUS	Children's data, parental consent, data minimization and student-record access

Purpose of this document

This document establishes the target maturity state for the NIST CSF 2.0 outcomes selected during Step 3. It converts the current-state assessment into a realistic target profile that can be used as the baseline for the formal gap register and remediation roadmap.

The assessment is deliberately tailored to an EdTech environment handling minors' data. The target state therefore gives additional weight to governance of children's information, parental-consent requirements, data minimization and access to student records.

1. Target-Maturity Methodology

LearnSphere is treated as an organization with some existing/ad hoc cybersecurity practices rather than a blank-slate environment. The target therefore represents the next credible operating state, not an idealized mature enterprise.

Internal 0–4 scoring model: 0 = Not Performed; 1 = Ad Hoc; 2 = Repeatable; 3 = Defined; 4 = Managed/Optimized. This scoring model is used consistently across this project to compare current and target states.

NIST terminology: NIST CSF 2.0 supports Current and Target Organizational Profiles. The internal 0–4 scale in this project should not be presented as an official NIST maturity scale. NIST Tiers are a separate mechanism for describing the rigor of cybersecurity risk governance and management.

2. Target-Setting Rules

Rule 1 — Current + 1: Most outcomes move one level because formalization and consistent evidence are realistic near-term improvements.

Rule 2 — Risk-based exception: A higher target is allowed when the risk exposure is material and the organization needs stronger management discipline.

Rule 3 — Avoid artificial maturity: Not every process should be targeted at Level 4. A universal Level-4 target would be unrealistic for the assumed size and maturity of LearnSphere.

Rule 4 — Evidence matters: A target is achieved only when the organization can demonstrate the expected outcome through documentation, implementation evidence, review records and measurable results where appropriate.

3. Detailed Target Maturity Assessment — GOVERN

GV.OC-03 — Legal, regulatory, contractual and privacy requirements

CURRENT	TARGET	GAP	PRIORITY
1	3	2	High

Current-state justification: Children's-data obligations, including parental-consent expectations, are not yet consistently translated into operational requirements owned by specific functions.

Target-state definition: Target state requires a documented requirements register, clear ownership, periodic review, and mapping of requirements into product, privacy, security and vendor processes.

Expected evidence at target: Requirements register; ownership/RACI; privacy/legal review records; policy updates; evidence that requirements are mapped to operational controls.

GV.RM-01 — Cybersecurity risk strategy

CURRENT	TARGET	GAP	PRIORITY
2	3	1	High

Current-state justification: Risk assessment exists, but new product features and changes to student-data processing do not consistently trigger a structured risk review.

Target-state definition: Target state integrates cyber risk review into change/product governance so material changes are assessed before implementation.

Expected evidence at target: Risk methodology; risk assessment template; change records showing risk review; management risk acceptance where applicable.

GV.RR-02 — Roles and responsibilities

CURRENT	TARGET	GAP	PRIORITY
2	3	1	High

Current-state justification: Security responsibilities exist, but accountability for children's-data governance, consent and minimization is not consistently formalized.

Target-state definition: Target state assigns accountable owners and supporting roles for children's-data governance and related decisions.

Expected evidence at target: RACI; job/role responsibilities; committee minutes; named data/security owners; escalation paths.

GV.PO-01 — Policy

CURRENT	TARGET	GAP	PRIORITY
2	3	1	High

Current-state justification: Policies provide a baseline but do not consistently translate children's-data protection into collection, consent, minimization, access and retention requirements.

Target-state definition: Target state uses policy as an enforceable governance mechanism with defined requirements, owners, review frequency and exception handling.

Expected evidence at target: Approved policies; policy review calendar; exception register; acknowledgement records; supporting standards/procedures.

4. Detailed Target Maturity Assessment — IDENTIFY

ID.AM-02 — Software, services and systems inventory

CURRENT	TARGET	GAP	PRIORITY
2	3	1	High

Current-state justification: Technology inventories exist in part, but relationships between systems/services and the student data they process are incomplete.

Target-state definition: Target state links applications, cloud services, databases and integrations to data types, owners and business purpose.

Expected evidence at target: Application/service inventory; data-flow mapping; system owners; AWS/service inventory; third-party integration list.

ID.AM-07 — Data and metadata inventories

CURRENT	TARGET	GAP	PRIORITY
1	3	2	Critical

Current-state justification: Sensitive student-data inventory is incomplete, making it difficult to determine exactly what designated data is collected, where it resides and why it is retained.

Target-state definition: Target state establishes a maintained inventory of designated data types and relevant metadata, including owner, location, purpose, classification and retention.

Expected evidence at target: Data inventory; metadata fields; data classification; system/location mapping; review evidence.

ID.RA-04 — Risk assessment for changes

CURRENT	TARGET	GAP	PRIORITY
2	3	1	High

Current-state justification: Changes to student-data processing do not consistently trigger a formal cybersecurity/privacy risk assessment.

Target-state definition: Target state makes risk review a defined gate for material processing changes, new integrations and significant product features.

Expected evidence at target: Change ticket; risk assessment; approval record; release gate; exception/waiver evidence.

ID.RA-05 — Risk of inappropriate data use/processing

CURRENT	TARGET	GAP	PRIORITY
2	3	1	High

Current-state justification: Data-minimization risk is not consistently considered when deciding what information a feature needs to collect or retain.

Target-state definition: Target state requires teams to justify required data elements and document unnecessary-data removal or compensating decisions.

Expected evidence at target: Data-field review; privacy/security assessment; feature design record; minimization checklist; approvals.

5. Detailed Target Maturity Assessment — PROTECT

PR.AA-05 — Access permissions and least privilege

CURRENT	TARGET	GAP	PRIORITY
2	4	2	Critical

Current-state justification: Access permissions and entitlements are managed, but student-record access requires stronger recurring certification, segregation of duties and privileged-access governance.

Target-state definition: Target state is managed/optimized: permissions are defined, enforced, periodically certified, measured and remediated with evidence. This is the single Level-4 target due to the sensitivity of student records.

Expected evidence at target: RBAC matrix; quarterly access certification; privileged-account register; joiner/mover/leaver evidence; access-review metrics; exception log.

Management rationale: Level 4 is intentionally selected here because access to student records is a critical exposure. The target requires recurring certification, measurable compliance, exception handling and continuous remediation rather than one-time documentation.

PR.AA-03 — Authentication

CURRENT	TARGET	GAP	PRIORITY
2	3	1	High

Current-state justification: Authentication requirements vary by system and access path, creating inconsistent protection for sensitive student environments.

Target-state definition: Target state defines minimum authentication requirements based on risk and applies them consistently to administrative and sensitive-data access.

Expected evidence at target: Authentication standard; MFA configuration; privileged access evidence; exception register; periodic compliance review.

PR.DS-01 — Data-at-rest and in-transit protection

CURRENT	TARGET	GAP	PRIORITY
2	3	1	High

Current-state justification: Protection requirements are not consistently mapped across databases, backups, exports, logs and third-party transfers.

Target-state definition: Target state documents protection requirements across the data lifecycle and verifies implementation for critical student-data stores.

Expected evidence at target: Encryption standard; AWS/database settings; backup protection evidence; transfer controls; periodic verification.

PR.DS-10 — Data lifecycle and disposal

CURRENT	TARGET	GAP	PRIORITY
1	3	2	High

Current-state justification: Retention and disposal are not consistently enforced, creating risk of holding student information longer than required.

Target-state definition: Target state defines retention periods, disposal triggers, responsible owners and evidence of secure deletion or approved archival.

Expected evidence at target: Retention schedule; deletion jobs; disposal logs; exception register; sample verification records.

6. Detailed Target Maturity Assessment — DETECT

DE.CM-01 — Network and system monitoring

CURRENT	TARGET	GAP	PRIORITY
2	3	1	High

Current-state justification: Monitoring exists, but coverage for critical assets and student-data environments is not consistently measured.

Target-state definition: Target state defines monitoring coverage objectives, ownership and review metrics for critical systems.

Expected evidence at target: Monitoring coverage matrix; SIEM onboarding list; dashboard/KPI; periodic coverage review; gap exceptions.

DE.CM-06 — External service provider monitoring

CURRENT	TARGET	GAP	PRIORITY
2	3	1	Medium-High

Current-state justification: Third-party monitoring expectations vary across suppliers and integrations.

Target-state definition: Target state establishes risk-based monitoring expectations and verifies provider reporting or evidence for critical services.

Expected evidence at target: Supplier security requirements; contracts; review records; provider reports; escalation evidence.

DE.AE-02 — Event analysis

CURRENT	TARGET	GAP	PRIORITY
2	3	1	High

Current-state justification: Alert investigation occurs, but metrics and documentation are not consistently standardized.

Target-state definition: Target state uses defined investigation records and measures detection/triage performance such as MTTD/MTTI where appropriate.

Expected evidence at target: Incident/SIEM tickets; investigation template; KPI dashboard; trend reviews; escalation records.

DE.AE-04 — Event correlation

CURRENT	TARGET	GAP	PRIORITY
1	3	2	Critical

Current-state justification: Correlation between IAM activity, application events and access to student records is not consistently defined.

Target-state definition: Target state creates usable correlation rules for high-risk access patterns and validates their effectiveness.

Expected evidence at target: Correlation rules; SIEM use cases; test alerts; tuning records; investigation samples.

7. Detailed Target Maturity Assessment — RESPOND

RS.MA-01 — Incident management

CURRENT	TARGET	GAP	PRIORITY
2	3	1	High

Current-state justification: Incident handling exists, but severity criteria do not consistently distinguish children's-data incidents from ordinary security events.

Target-state definition: Target state includes data-sensitivity-based severity, escalation and decision criteria.

Expected evidence at target: Incident severity matrix; incident response plan; escalation matrix; sample incident records.

RS.AN-03 — Incident analysis

CURRENT	TARGET	GAP	PRIORITY
2	3	1	High

Current-state justification: Evidence collection for suspected unauthorized student-record access is not standardized.

Target-state definition: Target state defines evidence sources, preservation requirements, analysis steps and chain-of-custody expectations appropriate to the incident.

Expected evidence at target: Forensic/evidence procedure; log sources; evidence checklist; incident records; lessons learned.

RS.CO-02 — Incident communication

CURRENT	TARGET	GAP	PRIORITY
2	3	1	Medium-High

Current-state justification: Communication roles and escalation paths for student-data incidents need clearer definition.

Target-state definition: Target state identifies decision-makers, internal escalation, customer communication responsibilities and approved communication channels.

Expected evidence at target: Communication matrix; contact list; notification workflow; exercise records; approval evidence.

RS.MI-01 — Incident containment

CURRENT	TARGET	GAP	PRIORITY
2	3	1	High

Current-state justification: Predefined playbooks for compromised student records are incomplete.

Target-state definition: Target state provides repeatable containment actions for unauthorized access, credential compromise, data exposure and related scenarios.

Expected evidence at target: Playbooks; tabletop exercises; containment checklists; post-exercise actions.

8. Detailed Target Maturity Assessment — RECOVER

RC.RP-01 — Recovery plan execution

CURRENT	TARGET	GAP	PRIORITY
2	3	1	Medium-High

Current-state justification: Recovery testing is not consistently scenario-based for ransomware, database compromise or student-data loss.

Target-state definition: Target state tests realistic scenarios and records recovery performance, issues and corrective actions.

Expected evidence at target: Recovery plan; exercise reports; test evidence; issue log; corrective-action tracking.

RC.RP-03 — Recovery priorities and dependencies

CURRENT	TARGET	GAP	PRIORITY
2	3	1	Medium

Current-state justification: Recovery priorities and technical dependencies are not consistently documented against RTO/RPO requirements.

Target-state definition: Target state links critical student services, databases, backups and dependencies to approved recovery objectives.

Expected evidence at target: BIA; RTO/RPO register; dependency map; recovery sequence; test results.

RC.CO-02 — Recovery communications

CURRENT	TARGET	GAP	PRIORITY
2	3	1	Medium

Current-state justification: Communication requirements for student-service disruption and recovery need clearer definition.

Target-state definition: Target state defines stakeholder groups, responsible owners, approval requirements and communication timing for recovery events.

Expected evidence at target: Recovery communication plan; stakeholder matrix; templates; exercise records.

RC.IM-01 — Lessons learned

CURRENT	TARGET	GAP	PRIORITY
1	3	2	Medium

Current-state justification: Lessons learned are not systematically converted into tracked, owned and closed improvement actions.

Target-state definition: Target state establishes a closed-loop improvement process after incidents, exercises and significant control failures.

Expected evidence at target: Post-incident reviews; action tracker; owners/dates; closure evidence; management review records.

10. Function-Level Target Profile Summary

FUNCTION	CURRENT AVG.	TARGET AVG.	GAP	PRIORITY	TARGET EMPHASIS
Govern (GV)	1.75	3.00	1.25	High	Children's-data governance, accountability and requirements
Identify (ID)	1.75	3.00	1.25	High	Data visibility, inventory, minimization and processing risk
Protect (PR)	1.75	3.25	1.50	Critical	Student-record access, authentication and data lifecycle
Detect (DE)	1.75	3.00	1.25	High	Monitoring coverage, correlation and investigation
Respond (RS)	2.00	3.00	1.00	Medium-High	Children's-data incident severity, evidence and playbooks
Recover (RC)	1.75	3.00	1.25	Medium	Scenario recovery, dependencies and lessons learned

11. Overall Target Maturity Position

Overall current maturity: 1.79 / 4.00

Overall target maturity: 3.04 / 4.00

Overall maturity gap: 1.25 levels

The target profile represents a transition from inconsistent and partially repeatable practices to a defined, evidence-based operating model. The Protect Function receives the strongest target because the organization processes sensitive student records and because access control is directly connected to confidentiality and misuse risk.

The target profile does not require LearnSphere to become fully optimized across every cybersecurity outcome. Instead, it creates a credible management baseline from which metrics, assurance activities and continuous improvement can be added over time.

12. Target Profile Priority Areas

PRIORITY	AREA	NIST OUTCOMES	TARGET MANAGEMENT ACTION
1	Children's-data governance	GV.OC-03, GV.RR-02, GV.PO-01	Document requirements, assign owners, formalize consent/privacy obligations and integrate them into operational processes.
2	Student-data visibility & minimization	ID.AM-07, ID.RA-04, ID.RA-05	Maintain designated-data inventory and make minimization/risk review part of product and processing changes.
3	Student-record access	PR.AA-05, PR.AA-03	Strengthen RBAC, least privilege, privileged access, authentication and recurring certification.
4	Unauthorized-access detection	DE.AE-04, DE.CM-01	Improve monitoring coverage and correlation of IAM, application and student-record access events.
5	Children's-data response	RS.MA-01, RS.AN-03, RS.MI-01	Create severity criteria, evidence procedures and repeatable playbooks for student-data incidents.
6	Recovery & improvement	RC.RP-01, RC.RP-03, RC.IM-01	Test realistic recovery scenarios and convert lessons learned into tracked improvements.

13. Target-State Acceptance Criteria

The target profile should be considered achieved only when the following characteristics are demonstrable for the applicable outcomes:

1. **Documented:** Requirements, standards, procedures, roles and review frequencies are formally approved and accessible.
2. **Implemented:** The documented requirement is operating in relevant systems, teams and processes.
3. **Consistent:** Sampling demonstrates that the process is not dependent on individual staff members or isolated manual effort.
4. **Owned:** Each outcome has a responsible function and escalation route.
5. **Measured where appropriate:** High-risk processes such as access review, monitoring and incident response have meaningful performance indicators.
6. **Improved:** Exceptions and failures produce tracked corrective actions and evidence of closure.

14. Management Target-State Statement

At the target state, LearnSphere should be able to demonstrate that children's-data requirements are explicitly owned and mapped; parental-consent requirements are governed through documented requirements and evidence; student-data inventories are maintained; minimization is assessed before collection and during material change; access to student records is restricted according to least privilege and reviewed at defined intervals; privileged access is governed; monitoring coverage and investigation performance are measurable; children's-data incidents have repeatable response playbooks; and recovery exercises produce tracked improvement actions.

15. Link to Step 5 — Formal Gap Analysis

Step 4 establishes **where LearnSphere wants to be**. Step 5 should compare each current outcome against this target and document the actual gap. The gap register should contain, at minimum:

- Gap ID and NIST CSF reference
- Current condition and target condition
- Business/security impact
- Root cause or contributing factor
- Recommended remediation
- Risk priority
- Responsible owner
- Target completion date
- Required evidence / closure criteria

This separation keeps the assessment professional: Step 3 describes the current state, Step 4 defines the target state, Step 5 records the gap, and the remediation roadmap then sequences the work.

Approval

ROLE	NAME	SIGNATURE	DATE
Prepared By	Mr. Meejan Shaikh – GRC Analyst	_____	04/09/2026
Reviewed By	Information Security Manager	_____	04/09/2026
Approved By	CISO	_____	04/09/2026